CASE STUDY: MedPay Cloud

Module 9, Lab 2: Compliance Package

1. Company

- SaaS health billing tool, 80 employees, 300 clinics as customers
- Patients view and pay clinic bills online through a MedPay portal
- Goal: win hospital contracts. Hospitals ask for HIPAA proof and PCI proof within 12 months

2. Data held

- PHI: patient name, date of birth, insurance ID, treatment codes, invoices
- Cardholder data: card number (PAN), name, expiry. CVV is typed at checkout and not stored
- Employee HR data

3. Vendors

- **CloudHost:** cloud infrastructure provider. Runs the app and the billing database
- **DeskSupport:** SaaS ticketing tool used by the support team
- **PayGate:** payment processor. Authorizes card payments
- **MailSend:** email vendor. Sends invoice emails to patients

4. Data flow today

- Patient opens portal, MedPay web app runs on CloudHost
- Billing database on CloudHost holds PHI and invoices
- Card form is on a MedPay page. Card data goes to the MedPay app server, then to PayGate
- Card number is also saved, encrypted, in the billing database for recurring payments
- Invoice emails with patient name and amount go out through MailSend
- Support staff paste patient screenshots into DeskSupport tickets

5. Owners

- CEO Amna: final approval
- CTO Daniyal: cloud and app
- Compliance Officer Sana: HIPAA and PCI obligations
- Head of IT Kamran: accounts, vendors, contracts
- Head of Support Fahad: patient and customer data
- You: GRC lead

6. Known facts

- Card number is stored in the billing database
- PHI systems and card systems share one flat network
- BAA with CloudHost was signed in 2022 and never reviewed
- No BAA with DeskSupport
- Invoice emails contain patient names
- PayGate AOC was never collected
- No written split of PCI duties between MedPay and CloudHost
- No list of vendors and which data each one touches
- Teams add new SaaS tools on their own, with no approval step
- No yearly compliance plan or review dates
- Nobody is named to decide if a breach must be reported

7. Documents given to you

- Sample BAA (CloudHost)
- Sample SOC 2 summary (CloudHost)
- Sample AOC (PayGate)
- Templates: MedPay DataFlow, MedPay BAA, MedPay PCI, MedPay Vendor, MedPay RACI

8. Your tasks

- **Task 1, Data flow:** fill the data flow table. Draw PHI and card data flow. Mark HIPAA scope (blue) and PCI CDE (red). Propose one scope-reduction change (tokenization or hosted payment page) and show the new scope
- **Task 2, BAA review:** check the sample BAA for 6 items: permitted use, safeguards, breach notice time, subcontractors, return/destruction, audit. Also check which CloudHost services it covers. List gaps and write 3 or more redline requests
- **Task 3, Vendor review:** read the CloudHost SOC 2 summary and the PayGate AOC. Record scope, period, exceptions, CUECs and AOC validity. Note which CUECs have an owner at MedPay. Give a verdict: safe to use, yes or no, and why
- **Task 4, PCI matrix:** 10 requirements. Mark each provider, customer, or shared. Add reason, evidence needed and evidence owner
- **Task 5, RACI:** RACI for 6 activities (risk assessment, BAA renewal, vendor review, policy review, evidence collection, breach notification decision). One A per row

9. Rules

- Paper work only. Do not design technical fixes
- One owner per control. One "A" per RACI row
- Every gap or decision needs a written reason
- Keep your files consistent: the scope change in Task 1 should match the PCI matrix in Task 4

10. Deliverables

- Completed data flow table and scoped diagram (before and after)
- BAA checklist with redline requests
- Vendor review page (SOC 2 and AOC)
- PCI responsibility matrix
- RACI chart
- One paragraph: top 3 gaps and why they matter for compliance